# 23.09.2026

# Themenblock 6

# Berechtigungskonzepte und Verzeichnisdienste

# Überblick

- Active Directory: Struktur (Forest, Domain, OU), GPOs, Gruppentypen
- RBAC-Prinzip: Konzeption für ein Szenario (welche Rolle bekommt welche Rechte)
- Prinzip der minimalen Rechtevergabe (Least Privilege)
- Authentifizierung vs. Autorisierung (sauber unterscheiden)
- MFA: Faktoren, typische Implementierungen
- LDAP als Protokoll (Grundverständnis reicht)

# Verzeichnisdienste

# Warum Verzeichnisdienste?

In jedem Unternehmen mit mehr als wenigen Computern stellt sich die Frage:

Wie verwaltet man zentral,

- wer sich an welchem Rechner anmelden darf?
- welche Ressourcen er nutzen darf?
- welche Einstellungen für welche Nutzer oder Geräte gelten?

Ohne zentrale Verwaltung müsste jeder Computer einzeln konfiguriert werden und das wäre ein Albtraum bei hundert oder tausend Geräten. Verzeichnisdienste lösen dieses Problem, indem sie Benutzer, Gruppen, Computer und Berechtigungen zentral speichern und verwalten.

# Warum Verzeichnisdienste?

**Der bekannteste und in Windows-Umgebungen praktisch allgegenwärtige Verzeichnisdienst ist Active Directory.**

# Die Domain als Grundeinheit

Die kleinste organisatorische Einheit in Active Directory ist die Domain (Domäne).

- Eine Domain ist eine logische Gruppierung von Benutzern, Computern und anderen Objekten, die eine gemeinsame Datenbank und gemeinsame Sicherheitsrichtlinien teilen.
- Jede Domain hat einen eindeutigen Namen.
- Der Name wird typischerweise in DNS-Namensform, etwa firma.local, angegeben.

# Die Domain als Grundeinheit

Innerhalb einer Domain verwaltet Active Directory zentral,

- welche Benutzer existieren,
- welche Passwörter gelten,
- welche Computer Mitglied der Domain sind und
- welche grundlegenden Sicherheitsrichtlinien gelten.

Ein Domain Controller ist der Server, der diese Datenbank vorhält und Anmeldeanfragen verarbeitet. In größeren Umgebungen gibt es mehrere Domain Controller, die sich gegenseitig replizieren, um Ausfallsicherheit zu gewährleisten.

# Tree und Forest: Mehrere Domains kombinieren

**Größere Unternehmen kommen oft mit einer einzigen Domain nicht aus — etwa weil verschiedene Tochtergesellschaften eigene Verwaltungsbereiche brauchen.**

# Tree und Forest: Mehrere Domains kombinieren

- Mehrere Domains, die einen zusammenhängenden Namensraum bilden (etwa firma.local und vertrieb.firma.local), bezeichnet man als Tree (Baum).
- Mehrere Trees (auch mit unterschiedlichen Namensräumen), die aber durch gegenseitige Vertrauensstellungen verbunden sind, bilden zusammen einen Forest (Gesamtstruktur).

Der Forest ist die oberste Organisationseinheit in Active Directory: Innerhalb eines Forests vertrauen sich alle Domains gegenseitig automatisch. Das bedeutet, dass Benutzer einer Domain auf Ressourcen einer anderen Domain im selben Forest zugreifen können, sofern sie die entsprechenden Berechtigungen haben.

# Organizational Units (OUs)

Innerhalb einer Domain werden Benutzer, Computer und Gruppen meist nicht "flach" verwaltet, sondern in Organizational Units (OUs) strukturiert.

- Eine OU ist ein Container, der dazu dient, Objekte logisch zu gruppieren: typischerweise entlang der Unternehmensstruktur, etwa nach Abteilungen (Vertrieb, IT, Buchhaltung) oder nach Standorten.

Vorteil: Gruppenrichtlinien (GPOs) lassen sich gezielt auf einzelne OUs anwenden.

OUs sind reine Verwaltungsstrukturen innerhalb einer Domain. Sie haben keine eigenen Sicherheitsgrenzen wie Domains oder Forests, sondern dienen der übersichtlichen Organisation und der gezielten Anwendung von Richtlinien.

# Group Policy Objects (GPOs)

- Ein Group Policy Object (GPO) ist eine Sammlung von Konfigurationseinstellungen, die zentral definiert und automatisch auf Benutzer oder Computer angewendet werden, die einer bestimmten Domain, OU oder einem bestimmten Standort zugeordnet sind.

Über GPOs lassen sich sehr unterschiedliche Dinge steuern: Passwortrichtlinien (Mindestlänge, Komplexität, Ablaufzeit), Desktop-Einstellungen, installierte Software, Laufwerksverbindungen, Sicherheitseinstellungen oder der Zugriff auf bestimmte Systemfunktionen.

# Group Policy Objects (GPOs)

## Vorteil: die zentrale Steuerung

- Eine Änderung an einem GPO wirkt sich automatisch auf alle betroffenen Computer und Benutzer aus, ohne dass jedes Gerät einzeln konfiguriert werden muss.
- GPOs werden hierarchisch vererbt (von der Domain über die OU-Struktur nach unten) wobei spezifischere Richtlinien (auf OU-Ebene) allgemeinere Richtlinien (auf Domain-Ebene) überschreiben können.

# Gruppentypen in Active Directory

In Active Directory gibt es zwei grundlegende Gruppentypen mit unterschiedlichem Zweck:

- Sicherheitsgruppen (Security Groups) werden verwendet, um Berechtigungen zu vergeben: eine Sicherheitsgruppe kann Mitglied einer Zugriffsliste (ACL) auf eine Datei, einen Ordner oder eine Anwendung sein, und alle Mitglieder der Gruppe erhalten automatisch diese Berechtigung
- Verteilergruppen (Distribution Groups) dienen ausschließlich der Kommunikation (etwa als E-Mail-Verteilerliste) und haben keine Berechtigungsfunktion.

# Gruppentypen in Active Directory

Zusätzlich unterscheidet man bei Sicherheitsgruppen den Gültigkeitsbereich (Scope):

- Globale Gruppen können Mitglieder aus der eigenen Domain enthalten und in der gesamten Domain oder im Forest verwendet werden.
- Domänenlokale Gruppen können Mitglieder aus verschiedenen Domains enthalten, werden aber nur innerhalb der eigenen Domain für Berechtigungen genutzt.
- Universelle Gruppen können Mitglieder aus dem gesamten Forest enthalten und forest-weit verwendet werden.

# Prüfungsrelevante Einordnung



In der AP2 wird die AD-Struktur meist anhand eines Unternehmens-szenarios geprüft, bei dem eine sinnvolle Struktur aus Domains, OUs und Gruppen entworfen oder erklärt werden soll.

Eine typische Aufgabe könnte lauten:
„Ein Unternehmen mit den Abteilungen Vertrieb, IT und Buchhaltung möchte für jede Abteilung unterschiedliche Sicherheitsrichtlinien (z.B. Passwortrichtlinien) durchsetzen. Schlagen Sie eine geeignete AD-Struktur vor und erklären Sie, wie die Richtlinien umgesetzt werden.“

# Prüfungsrelevante Einordnung



Die erwartete Antwort schlägt OUs für jede Abteilung vor.

Sie erklärt, dass GPOs auf OU-Ebene verknüpft werden, um abteilungs-spezifische Richtlinien durchzusetzen.

Bei Bedarf wird erläutert, wann eine zweite Domain statt einer OU sinnvoll wäre: nämlich wenn echte administrative Trennung benötigt wird, nicht nur unterschiedliche Richtlinien.

Wichtig ist, OU und Domain klar zu unterscheiden: OUs strukturieren, Domains trennen Sicherheitsgrenzen.

# RBAC
# Role-Based Access Control

# Einleitung

## Das Problem: Berechtigungen pro Benutzer sind nicht skalierbar

In einem kleinen Unternehmen mit wenigen Mitarbeitern lassen sich Zugriffsrechte problemlos individuell pro Benutzer vergeben:

- Benutzer A darf auf Ordner X zugreifen
- Benutzer B auf Ordner Y
- usw.

# Einleitung

Doch sobald ein Unternehmen wächst, wird dieser Ansatz schnell unübersichtlich und fehleranfällig:

- Bei jedem neuen Mitarbeiter müssen alle benötigten Rechte einzeln vergeben werden.
- Bei jedem Abteilungswechsel müssen alte Rechte entzogen und neue vergeben werden.
- Niemand hat mehr den Überblick, wer eigentlich worauf Zugriff hat.

# Einleitung

**RBAC (Role-Based Access Control, also rollenbasierte Zugriffskontrolle) löst dieses Problem durch eine zusätzliche Ebene zwischen Benutzern und Berechtigungen: die Rolle.**

# Das Grundprinzip von RBAC

- Bei RBAC werden Berechtigungen nicht direkt einzelnen Benutzern zugewiesen, sondern an Rollen gebunden.
- Dann werden Benutzern Rollen zugewiesen.

Eine Rolle bündelt alle Berechtigungen, die eine bestimmte Funktion im Unternehmen benötigt (etwa die Rolle "Buchhalter", "IT-Administrator" oder "Vertriebsmitarbeiter").

Jeder Benutzer erhält eine oder mehrere dieser Rollen, und automatisch alle damit verbundenen Berechtigungen.

# Das Grundprinzip von RBAC

## Warum macht man das?

- Ändert sich, welche Rechte eine Rolle benötigt, muss diese Änderung nur einmal an der Rolle vorgenommen werden und wirkt sich automatisch auf alle Benutzer mit dieser Rolle aus.
- Wechselt ein Mitarbeiter die Abteilung, wird ihm einfach die alte Rolle entzogen und die neue zugewiesen. Alle zugehörigen Berechtigungen ändern sich automatisch mit.

# Benutzer, Rollen, Berechtigungen

Das RBAC-Modell ist 3-stufig:

- Auf der untersten Ebene stehen die Berechtigungen (Permissions): konkrete Zugriffsrechte auf Ressourcen, etwa "Lesen von Finanzen-Ordner" oder "Schreiben in Kunden-Datenbank".
- Auf der mittleren Ebene stehen die Rollen: sie bündeln eine sinnvolle Kombination von Berechtigungen, die zusammen eine bestimmte Funktion ermöglichen.
- Auf der obersten Ebene stehen die Benutzer: ihnen werden eine oder mehrere Rollen zugewiesen.

# Benutzer, Rollen, Berechtigungen

Diese Trennung ist der Kern des Konzepts:

- Es gibt keine direkte Verbindung zwischen einem einzelnen Benutzer und einer einzelnen Berechtigung. Alles läuft über die Rolle als vermittelnde Schicht.
- In Active-Directory-Umgebungen werden Rollen häufig über Sicherheitsgruppen umgesetzt: Eine Gruppe entspricht einer Rolle, ihr werden Berechtigungen zugewiesen, und Benutzer werden als Mitglieder in die Gruppe aufgenommen.

# Eine Rollenstruktur entwerfen

Für die AP2 ist die wichtigste Fähigkeit: für ein gegebenes Unternehmensszenario eine sinnvolle Rollenstruktur zu entwerfen.

- Zunächst identifiziert man die unterschiedlichen Funktionsbereiche oder Tätigkeitsprofile im Unternehmen: etwa Geschäftsführung, Buchhaltung, Vertrieb, IT-Administration, allgemeine Mitarbeiter.
- Für jeden dieser Bereiche überlegt man dann, welche Ressourcen und welche Art von Zugriff (Lesen, Schreiben, Ändern, Löschen, Administrieren) tatsächlich benötigt werden.

# Eine Rollenstruktur entwerfen

- Daraus ergeben sich die Rollen und jede Rolle erhält genau die Berechtigungen, die für die jeweilige Funktion erforderlich sind, nicht mehr und nicht weniger.
- Wichtig ist dabei, dass eine Rolle eine Funktion beschreibt, keine Person: mehrere Personen können dieselbe Rolle haben, und eine Person kann auch mehrere Rollen gleichzeitig einnehmen, wenn sie mehrere Funktionen ausübt.

# Eine Rollenstruktur entwerfen

- Die Rolle "Vertriebsmitarbeiter" benötigt Lesezugriff auf den Kundenstamm und Schreibzugriff auf Angebote und Aufträge, aber keinen Zugriff auf Gehaltsdaten oder Buchhaltungssysteme.
- Die Rolle "Buchhaltung" benötigt Zugriff auf Finanzdaten, Rechnungen und Gehaltsabrechnungen, aber keinen Zugriff auf technische Systeme.
- Die Rolle "IT-Administrator" benötigt administrativen Zugriff auf Server, Netzwerk und Benutzerverwaltung — aber nicht auf vertrauliche Geschäftsdaten wie Gehaltslisten, usw.

Ein Mitarbeiter, der sowohl im Vertrieb arbeitet als auch Buchhaltungsaufgaben übernimmt, bekommt beide Rollen zugewiesen und erhält die Kombination der Berechtigungen.

# Vorteile von RBAC im Überblick

- Die Verwaltung wird deutlich einfacher, weil Berechtigungs-änderungen zentral an der Rolle vorgenommen werden, statt jeden betroffenen Benutzer einzeln zu bearbeiten.
- Das Onboarding neuer Mitarbeiter wird beschleunigt, denn ein neuer Mitarbeiter erhält sofort alle benötigten Rechte durch Zuweisung der passenden Rolle.
- Das Offboarding wird beschleunigt, denn ein ausscheidender Mitarbeiter verliert durch Entzug der Rolle automatisch alle zugehörigen Rechte.

# Vorteile von RBAC im Überblick

- Die Nachvollziehbarkeit steigt: Es ist jederzeit erkennbar, welche Rolle welche Rechte hat und welche Benutzer welche Rolle besitzen (das erleichtert Audits und Sicherheitsüberprüfungen).
- Und schließlich unterstützt RBAC direkt das Prinzip der minimalen Rechtevergabe (Least Privilege).

# Prüfungsrelevante Einordnung



In der AP2 wird RBAC meist anhand eines Szenarios geprüft, bei dem für ein Unternehmen mit beschriebenen Abteilungen oder Tätigkeitsprofilen eine Rollenstruktur entworfen werden soll.

Eine typische Aufgabe könnte lauten:
„Ein Unternehmen hat die Abteilungen Personalwesen, Vertrieb und IT. Entwerfen Sie ein Rollenkonzept nach dem RBAC-Prinzip und ordnen Sie jeder Rolle passende Berechtigungen zu.“

# Prüfungsrelevante Einordnung



Die erwartete Antwort definiert für jede Abteilung eine eigene Rolle, beschreibt konkret, welche Zugriffsrechte diese Rolle benötigt, und begründet, warum bestimmte Rechte bewusst ausgeschlossen werden (bspw. „Vertriebsmitarbeiter haben keinen Zugriff auf Personalakten“).

Wer zusätzlich erklärt, wie die Umsetzung technisch erfolgen könnte (etwa über AD-Sicherheitsgruppen als Abbildung der Rollen) zeigt, dass das Konzept nicht nur theoretisch verstanden, sondern auch praktisch einordbar ist.

# Least Privilege

# Einleitung


Least Privilege*
NEW EMPLOYEE
GUEST
This authorizes you to your desk. And to the restroom. That's it.
NEW AI AGENT
ACCESSES
PROD
AWS
ROOT
DB
CRM
EMAIL
PAYMENTS
SUPPORT
CALENDAR
This authorizes you to... honestly, I don't know what this *doesn't* unlock.

# Nicht mehr Rechte als nötig

- Das Prinzip der minimalen Rechtevergabe ("Least Privilege“) ist eines der grundlegendsten Sicherheitsprinzipien der IT überhaupt, und es zieht sich durch nahezu alle Bereiche der Systemadministration.
- Die Kernidee lässt sich in einem Satz zusammenfassen: Jeder Benutzer, jeder Prozess und jedes System sollte nur genau die Rechte besitzen, die für die jeweilige Aufgabe unbedingt erforderlich sind und nicht mehr.

Für die AP2 ist wichtig, dieses Prinzip nicht nur zu kennen, sondern seine Begründung und seine praktischen Konsequenzen erklären zu können.

# Weniger Angriffsfläche

- Jedes Recht, das ein Benutzer oder ein Prozess besitzt, ist ein potenzieller Hebel für einen Angreifer (sei es durch gestohlene Zugangsdaten, eine kompromittierte Anwendung oder einen Insider mit schädlicher Absicht).
- Hat ein Benutzer mehr Rechte als nötig, kann ein Angreifer, der diesen Account übernimmt, mehr Schaden anrichten.

# Weniger Angriffsfläche

## Beispiel

- Wird ein normaler Mitarbeiter-Account, der nur Leserechte auf seine eigenen Dateien hat, kompromittiert, ist der Schaden begrenzt.
- Wird hingegen ein Account mit administrativen Rechten auf die gesamte Domäne kompromittiert, kann der Angreifer im Extremfall die gesamte IT-Infrastruktur übernehmen.

Least Privilege begrenzt also nicht die Wahrscheinlichkeit eines Angriffs, sondern dessen mögliches Ausmaß.

# Getrennte Accounts bei Benutzern

- Ein Administrator benötigt für seine alltäglichen Aufgaben (Mails lesen, im Internet recherchieren, Dokumente bearbeiten) keine administrativen Rechte. Diese Aufgaben sollten über einen normalen Benutzer-Account erfolgen.
- Administrative Rechte werden nur dann genutzt, wenn sie tatsächlich für eine administrative Tätigkeit benötigt werden (etwa über einen separaten, dedizierten Admin-Account, der ausschließlich für diese Zwecke verwendet wird).

# Getrennte Accounts bei Diensten

- Ein Webserver-Dienst, der nur Dateien aus einem bestimmten Verzeichnis ausliefern muss, muss nicht mit Administratorrechten laufen.
- Denn wenn dieser Dienst durch eine Sicherheitslücke kompromittiert wird, erhält ein Angreifer automatisch dieselben Rechte, mit denen der Dienst läuft
- Läuft der Dienst mit minimalen Rechten (etwa nur Lesezugriff auf das benötigte Verzeichnis) bleibt der potenzielle Schaden im Falle einer Kompromittierung deutlich begrenzter.

# Getrennte Accounts bei Anwendungen

- Dasselbe gilt für Datenbankverbindungen von Anwendungen.
- Eine Anwendung, die nur Daten lesen muss, sollte sich mit einem Datenbankbenutzer verbinden, der ausschließlich Leserechte hat und nicht mit einem Account, der auch Tabellen löschen oder die Datenbankstruktur ändern könnte.

# Least Privilege und  RBAC

Least Privilege und RBAC ergänzen sich:

- RBAC ist die Struktur, mit der Rechte organisiert werden.
- Least Privilege ist das Prinzip, das bestimmt, wie diese Rechte innerhalb der Struktur bemessen werden.

Eine Rolle nach RBAC zu definieren, bedeutet automatisch, sich die Frage zu stellen: Welche Rechte braucht diese Funktion tatsächlich minimal?

# Privilege Creep

Least Privilege muss regelmäßig überprüft werden.

- Mitarbeiter wechseln Abteilungen, übernehmen neue Aufgaben oder verlassen das Unternehmen und behalten dabei oft Rechte, die sie ursprünglich für eine frühere Aufgabe benötigt haben, aber inzwischen nicht mehr brauchen.
- Dieses Phänomen wird als "Privilege Creep" bezeichnet: eine schleichende Anhäufung nicht mehr benötigter Rechte, die durch regelmäßige Rechteüberprüfungen (Access Reviews) erkannt und korrigiert werden muss.

# Prüfungsrelevante Einordnung



In der AP2 wird Least Privilege häufig im Kontext eines Sicherheitskonzepts oder einer Berechtigungsvergabe geprüft: entweder als eigenständige Begründungsfrage oder eingebettet in ein größeres Szenario zu Berechtigungen oder Systemhärtung.

Eine typische Aufgabe könnte lauten:
„Ein IT-Administrator nutzt für alle täglichen Aufgaben (einschließlich E-Mail und Internetrecherche) seinen administrativen Account. Beurteilen Sie dieses Vorgehen aus Sicherheitssicht und schlagen Sie eine Verbesserung vor“

# Prüfungsrelevante Einordnung



Die erwartete Antwort benennt das Risiko (Kompromittierung des Accounts würde sofort administrative Rechte gewähren), erklärt das Prinzip von Least Privilege, und schlägt die Trennung in einen normalen Benutzer-Account und einen separaten Admin-Account vor, der nur bei Bedarf genutzt wird.

Wer zusätzlich den Begriff „Angriffsfläche“ oder „Privilege Creep“ einordnen kann, zeigt vertieftes Verständnis über die reine Begriffsdefinition hinaus.

# Authentifizierung vs. Autorisierung

# Einleitung

**Ein System kann eine Person zuverlässig identifizieren (Authentifizierung), aber dennoch falsch konfiguriert sein, was diese Person dann tun darf (Autorisierung) und umgekehrt.**

# Authentifizierung: Wer bist du?

Authentifizierung ist der Vorgang, bei dem ein System überprüft, ob jemand tatsächlich die Person ist, für die er sich ausgibt (Bestätigung einer Identität).

Der klassische Fall ist die Anmeldung mit Benutzername und Passwort:

- Der Benutzername gibt an, wer man zu sein behauptet.
- Das Passwort soll beweisen, dass diese Behauptung stimmt.

# Authentifizierung: Wer bist du?

Authentifizierung kann auf verschiedenen Faktoren basieren:

- Etwas, das man weiß (Passwort, PIN)
- Etwas, das man besitzt (Smartcard, Hardware-Token, Smartphone)
- Etwas, das man ist (biometrische Merkmale wie Fingerabdruck oder Gesichtserkennung)

# Authentifizierung: Wer bist du?

**Das Ergebnis der Authentifizierung ist eine einfache Aussage:**

**Diese Identität ist bestätigt. Oder nicht.**

# Autorisierung: Was darfst du?

Autorisierung ist der Vorgang, bei dem festgelegt und überprüft wird, welche Aktionen eine bereits authentifizierte Identität durchführen darf.

Es geht also nicht mehr darum, wer jemand ist, sondern darum, was diese Person mit ihrer bestätigten Identität tun darf: welche Dateien sie lesen, welche Systeme sie administrieren, welche Daten sie ändern darf.

# Autorisierung: Was darfst du?

**Autorisierung baut auf Berechtigungskonzepten wie bspw. RBAC auf (bei dem einer Rolle bestimmte Rechte zugewiesen werden).**

# Autorisierung: Was darfst du?

**Das Ergebnis der Autorisierung ist nicht eine einfache Ja/Nein-Aussage zur Identität, sondern eine differenzierte Antwort:**

**Diese Identität darf X tun, aber nicht Y.**

# Erst Authentifizierung, dann Autorisierung

- Zuerst muss die Identität bestätigt werden (Authentifizierung).
- Dann kann geprüft werden, was diese Identität tun darf (Autorisierung).

Ohne erfolgreiche Authentifizierung gibt es keine sinnvolle Autorisierung, denn das System weiß ja noch nicht, mit wem es überhaupt zu tun hat.

# Beispiel

- Der Pförtner, der einen Mitarbeiterausweis kontrolliert, führt eine Authentifizierung durch: er stellt fest, wer die Person ist.
- Ob diese Person dann Zugang zum Serverraum, zum Lager oder nur zum Empfangsbereich hat, ist eine Frage der Autorisierung, die durch die Zugangsberechtigungen geregelt sind, die mit dieser Identität verknüpft sind.

# Typische Fehlermeldungen

- "401 Unauthorized" zeigt eine fehlgeschlagene Authentifizierung.
- "403 Forbidden" zeigt eine fehlgeschlagene Autorisierung.

# Prüfungsrelevante Einordnung



In der AP2 wird die Unterscheidung von Authentifizierung und Autorisierung meist in Kombination mit anderen Konzepten geprüft: etwa MFA (das die Authentifizierung stärkt) oder RBAC (das die Autorisierung strukturiert).

Eine typische Aufgabe könnte lauten:
„Erklären Sie den Unterschied zwischen Authentifizierung und Autorisierung anhand eines Beispiels aus der Unternehmenspraxis.“

# Prüfungsrelevante Einordnung



Die erwartete Antwort definiert Authentifizierung als Identitäts-prüfung ("Wer bist du?") und Autorisierung als Rechteprüfung ("Was darfst du?"), erklärt die Reihenfolge (erst Authentifizierung, dann Autorisierung) und untermauert beide Begriffe mit einem konkreten Beispiel: etwa der Anmeldung am System (Authentifizierung) versus dem Zugriff auf einen bestimmten Ordner (Autorisierung).

Wer beide Begriffe nur definiert, ohne den Zusammenhang und die Reihenfolge zu erklären, lässt einen Teil der Punkte liegen.

# MFA

# Warum ein einzelner Faktor nicht mehr reicht

- Ein Passwort allein gilt heute als unzureichender Schutz für den Zugang zu sensiblen Systemen.
- Passwörter können gestohlen werden: durch Phishing, durch Datenlecks bei anderen Diensten (wenn Nutzer Passwörter wiederverwenden), durch Keylogger oder durch einfaches Erraten bei schwachen Passwörtern.

# Warum ein einzelner Faktor nicht mehr reicht

- Multi-Faktor-Authentifizierung (MFA) begegnet diesem Problem, indem Authentifizierung nicht von einem einzigen Nachweis abhängig gemacht wird, sondern von der Kombination mehrerer unabhängiger Faktoren.
- Die Grundidee: Selbst wenn ein Angreifer einen Faktor kompromittiert (etwa das Passwort) fehlt ihm immer noch der zweite Faktor, um sich erfolgreich anzumelden.

# Die drei Faktorkategorien

MFA basiert auf drei grundsätzlich unterschiedlichen Kategorien von Faktoren, die jeweils auf einem anderen Prinzip beruhen.

1. Wissen — etwas, das nur die berechtigte Person weiß, etwa ein Passwort oder eine PIN.
2. Besitz — etwas, das nur die berechtigte Person hat, etwa ein Smartphone, eine Smartcard oder ein Hardware-Token.
3. Inhärenz — etwas, das die berechtigte Person ist, repräsentiert durch biometrische Merkmale wie Fingerabdruck, Gesichtserkennung oder Iris-Scan.

# Die drei Faktorkategorien

**Für echte Multi-Faktor-Authentifizierung müssen mindestens zwei dieser unterschiedlichen Kategorien kombiniert werden.**

**Zwei Passwörter zählen nicht als MFA, da beide aus derselben Kategorie (Wissen) stammen und damit demselben Angriffsvektor unterliegen.**

# Faktor 1: Wissen (Knowledge)

- Passwörter, PINs und Sicherheitsfragen: Der Wissensfaktor ist der älteste und am weitesten verbreitete Authentifizierungsfaktor.
- Vorteil: einfache Umsetzung (zusätzliche Hardware nötig, jeder kennt das Prinzip).
- Nachteil: Wissen kann kopiert, erraten, abgefangen, weitergegeben und genutzt werden, ohne dass die berechtigte Person etwas davon merkt.

Aus diesem Grund gilt der reine Wissensfaktor allein als schwächste Form der Authentifizierung. Weil er einfach und kostengünstig ist, bleibt er dennoch als erster Faktor in praktisch jeder MFA-Kombination relevant.

# Faktor 2: Besitz (Possession)

- Der Besitzfaktor basiert auf einem physischen Gegenstand, den nur die berechtigte Person hat.
- Typische Implementierungen sind Hardware-Token, die zeitbasierte Einmalcodes generieren (TOTP — Time-based One-Time Password), Smartcards mit Chip, oder das Smartphone, auf das per SMS oder App ein Code gesendet wird.
- Vorteil: Ein Angreifer, der nur das Passwort kennt, kann sich ohne den physischen Gegenstand nicht anmelden. Das Passwort allein nützt ihm nichts mehr.
- Nachteil: Geräte können verloren gehen, gestohlen werden oder anderweitig kompromittiert werden.

# Faktor 3: Inhärenz (Biometrie)

- Der Inhärenzfaktor nutzt körperliche Merkmale der Person selbst:  Fingerabdruck, Gesichtserkennung, Iris-Scan oder Stimmerkennung.
- Vorteil: Biometrische Merkmale können nicht vergessen werden wie ein Passwort und nicht verloren werden wie ein Token. Man hat sie immer "dabei".
- Nachteil ist: Biometrische Merkmale können nicht geändert werden. Wird ein Fingerabdruck-Datensatz kompromittiert, kann man (anders als bei einem Passwort) keinen "neuen Fingerabdruck" vergeben.

Zudem ist Biometrie nicht absolut fälschungssicher, und es gibt Datenschutzbedenken beim Speichern biometrischer Daten. In der Praxis wird Biometrie daher meist als bequemer zusätzlicher Faktor eingesetzt, seltener als alleiniger Schutz für hochsensible Systeme.

# Typische Implementierungen in der Praxis

- In Unternehmensumgebungen ist die häufigste MFA-Implementierung die Kombination aus Passwort (Wissen) und einem zeitbasierten Code aus einer Authenticator-App auf dem Smartphone (Besitz), wie etwa Microsoft Authenticator oder Google Authenticator.
- Diese Kombination ist kostengünstig, da kein zusätzliches Hardware-Token angeschafft werden muss, und bietet gleichzeitig einen deutlichen Sicherheitsgewinn gegenüber reiner Passwort-Authentifizierung.

# Typische Implementierungen in der Praxis

- In Umgebungen mit höheren Sicherheitsanforderungen kommen Hardware-Token zum Einsatz, die nicht durch Malware auf dem Smartphone kompromittiert werden können.
- Bei der Anmeldung an Notebooks ist die Kombination aus Passwort und Fingerabdruck- oder Gesichtserkennung verbreitet.
- Hier übernimmt die Biometrie die Rolle des zweiten Faktors.
- Sie wird oft kombiniert mit einem TPM-Chip (Trusted Platform Module), der die biometrischen Daten sicher im Gerät speichert.



# Prüfungsrelevante Einordnung



In der AP2 wird MFA häufig im Kontext eines Sicherheitskonzepts geprüft, bei dem ein Unternehmen seinen Authentifizierungsprozess absichern möchte.

Eine typische Aufgabe könnte lauten:
„Ein Unternehmen sichert den Zugang zu seinem VPN bislang nur mit Benutzername und Passwort ab. Schlagen Sie eine Verbesserung vor und begründen Sie diese.“

# Prüfungsrelevante Einordnung



Die erwartete Antwort empfiehlt die Einführung von MFA, nennt mindestens zwei unterschiedliche Faktorkategorien: etwa Passwort (Wissen) plus Authenticator-App (Besitz).

Sie begründet, warum diese Kombination das Sicherheitsniveau erhöht: „Ein gestohlenes Passwort allein reicht nicht mehr für den Zugriff“.

Eine häufige Zusatzfrage prüft, ob der Prüfling erkennt, dass zwei Passwörter oder zwei Wissensfaktoren keine echte MFA darstellen. Hier zeigt sich, ob das Kategorienprinzip verstanden wurde oder nur die Abkürzung "MFA" bekannt ist.

# LDAP

# Was ist LDAP?

LDAP (Lightweight Directory Access Protocol) ist ein Protokoll, mit dem auf Verzeichnisdienste zugegriffen werden kann.

Vereinfacht gesagt: LDAP ist die „Sprache“, über die Anwendungen mit einem Verzeichnis wie Active Directory kommunizieren, um Informationen über Benutzer, Gruppen, Computer oder andere Objekte abzufragen oder zu ändern.

# Was ist LDAP?

Wenn sich ein Benutzer an einer Anwendung anmeldet und diese Anmeldung gegen Active Directory geprüft wird, dann läuft diese Kommunikation typischerweise über LDAP ab.

Für die AP2 reicht ein grundlegendes Verständnis. Es wird nicht erwartet, LDAP-Abfragen selbst zu formulieren.

# Directory Information Tree (DIT)

LDAP-Verzeichnisse sind hierarchisch aufgebaut (vergleichbar mit einem Dateisystem, das aus Ordnern und Unterordnern besteht, nur dass hier Organisationseinheiten, Benutzer und Gruppen die "Objekte" sind).

Diese Struktur wird als Directory Information Tree (DIT) bezeichnet.

# Distinguished Name (DN)

Jedes Objekt im Verzeichnis hat einen eindeutigen Namen, den sogenannten Distinguished Name (DN), der seine Position in der Hierarchie beschreibt (ähnlich einem vollständigen Pfad).

Ein Benutzerobjekt enthält dabei verschiedene Attribute (bspw. Name, E-Mail-Adresse, Telefonnummer oder Gruppenmitgliedschaften).

LDAP definiert, wie solche hierarchisch organisierten Objekte und ihre Attribute abgefragt, durchsucht und verändert werden können.

# LDAP in der Praxis

LDAP ist überall dort relevant, wo Anwendungen zentral gespeicherte Benutzerinformationen nutzen wollen, statt eigene Benutzerverwaltungen zu pflegen.

- Eine E-Mail-Anwendung, die das Adressbuch aus Active Directory anzeigen will, fragt diese Informationen per LDAP ab.
- Eine Webanwendung, die sich nicht mit eigenen Benutzernamen und Passwörtern, sondern mit den vorhandenen Unternehmens-Zugangsdaten anmelden lassen soll, prüft die eingegebenen Zugangsdaten per LDAP gegen das Verzeichnis.
- Auch viele Netzwerkgeräte, Drucker oder Linux-Systeme können sich per LDAP gegen Active Directory authentifizieren, ohne eine eigene, separate Benutzerdatenbank führen zu müssen.

# Bedeutung

**LDAP ist damit ein wichtiger Baustein für die zentrale Benutzerverwaltung über verschiedene Systeme und Hersteller hinweg.**

# LDAP != Active Directory

- Active Directory ist ein konkreter Verzeichnisdienst: ein Produkt von Microsoft, das Benutzer, Computer, Gruppen und Richtlinien verwaltet.
- LDAP ist dagegen ein offenes, herstellerunabhängiges Protokoll, über das auf Verzeichnisdienste zugegriffen werden kann.
- Active Directory unterstützt LDAP als eine von mehreren Zugriffsmöglichkeiten, ist aber selbst weit mehr als nur LDAP.
- Andere Verzeichnisdienste, etwa OpenLDAP unter Linux, implementieren ebenfalls das LDAP-Protokoll.

# Prüfungsrelevante Einordnung



In der AP2 wird LDAP typischerweise in Form einer kurzen Erklärungsfrage oder eingebettet in ein Szenario, in dem eine Anwendung an ein Verzeichnis angebunden werden soll, geprüft.

Eine typische Frage könnte lauten:

„Eine neue Webanwendung soll Mitarbeitern erlauben, sich mit ihren bestehenden Unternehmens-Zugangsdaten anzumelden, statt einen neuen Account anzulegen. Welches Protokoll kommt hierfür typischerweise zum Einsatz, und was ist seine Funktion?“

# Prüfungsrelevante Einordnung



Die erwartete Antwort nennt LDAP, erklärt, dass es dem Zugriff auf Verzeichnisdienste wie Active Directory dient, und beschreibt knapp, dass die Anwendung die eingegebenen Zugangsdaten per LDAP gegen das Verzeichnis prüfen lässt.

Eine vertiefte Erklärung der hierarchischen Struktur (DIT, DN) wird selten verlangt. Wichtiger ist das Verständnis der Rolle von LDAP als Zugriffsprotokoll auf zentrale Benutzerverzeichnisse.

# Themenblock 7
# IT-Sicherheit auf Systemebene

# Überblick

- Härtungsmaßnahmen (Dienste deaktivieren, Ports schließen, Patchmanagement)
- Patchmanagement-Konzepte: Testumgebung → Staging → Produktion
- Logging und Monitoring
- Verschlüsselung auf Systemebene: BitLocker, TPM, Festplattenverschlüsselung
- BSI IT-Grundschutz: Schutzbedarfsanalyse, Grundschutz-Bausteine

# Härtungsmaßnahmen

# Einleitung

**Systemhärtung („Hardening“) bezeichnet die Gesamtheit der Maßnahmen, mit denen ein System so konfiguriert wird, dass es möglichst wenige Angriffsmöglichkeiten bietet.**

# Grundidee

- Jede aktive Funktion, jeder offene Port und jeder laufende Dienst ist ein potenzieller Angriffspunkt.
- Also sollte alles, was nicht benötigt wird, deaktiviert, entfernt oder geschlossen werden.

# Vorgehen

**Ein frisch installiertes Betriebssystem ist nicht gehärtet.**

**Es bringt viele Standardeinstellungen, Dienste und Funktionen mit, die für den allgemeinen Einsatz praktisch, aber für den konkreten Verwendungszweck eines Servers oft überflüssig und damit ein unnötiges Risiko sind.**

# → Nicht benötigte Dienste deaktivieren

- Jedes Betriebssystem startet standardmäßig eine Reihe von Diensten (Hintergrundprozesse, die bestimmte Funktionen bereitstellen, etwa Druckdienste, Remote-Verwaltungsdienste oder Netzwerkfreigaben).
- Auf einem Server, der ausschließlich als Webserver dient, werden die meisten dieser Dienste nicht benötigt.
- Jeder laufende Dienst, der nicht benötigt wird, ist dennoch ein potenzieller Angriffspunkt, denn er belegt Ressourcen, kann Sicherheitslücken enthalten, und wird möglicherweise gar nicht überwacht, weil niemand erwartet, dass er überhaupt aktiv ist.

# → Nicht benötigte Dienste deaktivieren

- Die Härtungsmaßnahme besteht darin, systematisch zu prüfen, welche Dienste für die jeweilige Funktion des Systems tatsächlich erforderlich sind, und alle anderen zu deaktivieren.
- Das reduziert nicht nur die Angriffsfläche, sondern verbessert oft auch die Performance, da weniger Hintergrundprozesse laufen und  Ressourcen verbrauchen.

# → Ports schließen

- Jeder Netzwerkdienst, der auf einem System läuft, ist über einen bestimmten Port erreichbar (ein Webserver typischerweise über Port 80 oder 443, ein MS SQL Server Datenbankserver über Port 1433, ein Remote-Desktop-Dienst über 3389, usw.).
- Ist ein Port geöffnet, kann von außen eine Verbindung zu dem dahinterliegenden Dienst aufgebaut werden, selbst wenn dieser Dienst gar nicht für die externe Nutzung gedacht war.

# → Ports schließen

- Die Härtungsmaßnahme besteht darin, mittels einer lokalen Firewall (Host-Firewall) nur die Ports zu öffnen, die für die Funktion des Systems tatsächlich erforderlich sind, und alle anderen zu schließen.
- Ein Webserver braucht typischerweise nur die Ports für HTTP/HTTPS.
- Administrative Zugänge wie SSH oder RDP sollten idealerweise nur aus einem begrenzten, vertrauenswürdigen Netzwerkbereich erreichbar sein und nicht aus dem gesamten Internet.

# → Patchmanagement

- Software enthält immer wieder Schwachstellen, die nach ihrer Entdeckung durch Hersteller-Updates geschlossen werden.
- Ein System, das nicht regelmäßig aktualisiert wird, sammelt mit der Zeit bekannte, öffentlich dokumentierte Schwachstellen an.
- Genau solche Schwachstellen sind für Angreifer besonders attraktiv, weil fertige Angriffswerkzeuge dafür oft frei verfügbar sind.
- Daher ist die dritte zentrale Säule der Systemhärtung das regelmäßige Einspielen von Sicherheitsupdates, das s. g. Patchmanagement.

# → Patchmanagement

- Härtung bedeutet hier, einen verlässlichen Prozess zu etablieren, der sicherstellt, dass sicherheitsrelevante Updates zeitnah eingespielt werden und nicht erst, wenn ein Problem bereits ausgenutzt wurde.

Wie ein solcher Patchmanagement-Prozess konkret aussieht, schauen wir uns in einem separaten Kapitel genauer an.

# → Standardpasswörter und Standard-Accounts

- Standardpasswörter und Standard-Accounts, die bei der Installation mitgeliefert werden, müssen geändert oder deaktiviert werden, denn sie sind oft öffentlich bekannt und ein beliebtes erstes Angriffsziel.

# → Nicht benötigte Software deinstallieren

- Nicht benötigte Software sollte deinstalliert werden, denn auch ungenutzte installierte Programme können Schwachstellen enthalten, ohne dass sie aktiv verwendet werden.

# → Sicherheitsrelevante Konfigurationen

- Sicherheitsrelevante Konfigurationsoptionen (etwa die Deaktivierung veralteter, unsicherer Protokolle (z.B. alte SMB- oder TLS-Versionen) sollten angepasst werden.

# → Bootvorgang

- Und schließlich gehört auch die physische und logische Absicherung des Bootvorgangs dazu, etwa durch ein BIOS/UEFI-Passwort, damit ein Angreifer mit physischem Zugriff das System nicht einfach von einem externen Medium neu starten kann.

# Prüfungsrelevante Einordnung



In der AP2 wird Systemhärtung meist als Teilaufgabe in einem größeren Sicherheitsszenario abgefragt: etwa bei der Konzeption eines neuen Servers oder bei der Bewertung eines unsicher konfigurierten Systems.

Eine typische Aufgabe könnte lauten:
"Ein Unternehmen nimmt einen neuen Webserver in Betrieb. Nennen Sie drei Maßnahmen zur Härtung dieses Systems und begründen Sie diese."

# Prüfungsrelevante Einordnung



Die erwartete Antwort nennt konkrete, aufeinander aufbauende Maßnahmen: die Deaktivierung nicht benötigter Dienste mit der Begründung der reduzierten Angriffsfläche, das Schließen aller Ports außer denen für HTTP/HTTPS, die Etablierung eines Patchmanagement-Prozesses.

Wichtig ist dabei immer die Begründung über das Prinzip der Angriffsflächenreduktion. Wer nur Maßnahmen aufzählt, ohne den dahinterliegenden Sicherheitsgedanken zu erklären, lässt Punkte liegen.

# Patchmanagement

# Einleitung

Die naheliegende Vorstellung von Patchmanagement ist simpel:
Ein Update wird verfügbar, also wird es installiert.

In der Praxis ist das jedoch riskant, denn ein Sicherheitsupdate kann selbst Probleme verursachen. Updates können Inkompatibilitäten mit bestehender Software auslösen, Konfigurationen verändern, oder in seltenen Fällen sogar neue Fehler einführen.

# Einleitung

Wird ein solches Update ungetestet direkt auf produktiven Systemen eingespielt, kann ein eigentlich gut gemeinter Sicherheitspatch zu einem Ausfall geschäftskritischer Systeme führen.

Professionelles Patchmanagement löst dieses Dilemma durch einen mehrstufigen Prozess, der das Risiko eines fehlerhaften Updates abfedert, bevor es die Produktivumgebung erreicht.

# Stufenweises Vorgehen

Der etablierte Ansatz im Patchmanagement besteht aus mehreren aufeinanderfolgenden Umgebungen, durch die ein Update durchläuft, bevor es im produktiven Betrieb ankommt.

Das gängige Modell besteht aus drei Stufen:

- Testumgebung
- Staging
- Produktion

# Stufenweises Vorgehen

Jede Stufe hat einen eigenen Zweck und eine eigene Fehlertoleranz.

Die grundlegende Logik dahinter: Je weiter ein Update im Prozess fortschreitet, desto näher kommt die Umgebung der realen Produktivumgebung und desto geringer wird das verbleibende Risiko, dass unentdeckte Probleme noch auftreten.

Gleichzeitig steigt mit jeder Stufe der potenzielle Schaden, wenn doch noch ein Problem auftritt.

Daher die schrittweise Annäherung statt eines direkten Sprungs.

# Testumgebung

- Die Testumgebung ist eine vom produktiven Betrieb komplett isolierte Umgebung, in der neue Updates zuerst eingespielt und überprüft werden.
- Sie bildet die wichtigsten Systeme und Anwendungen ab (oft auf virtuellen Maschinen, die mit geringem Aufwand erstellt, getestet und bei Problemen einfach verworfen werden können).
- In der Testumgebung wird geprüft, ob das Update grundlegend funktioniert: Lässt es sich installieren, startet das System danach korrekt, laufen die wichtigsten Anwendungen weiter wie erwartet?

Ein Fehler in der Testumgebung hat keine Auswirkung auf den laufenden Betrieb.

# Staging-Umgebung

- War ein Update in der Testumgebung erfolgreich, kommt es in die Staging-Umgebung.
- Die Staging-Umgebung ist der Produktivumgebung so ähnlich wie möglich (idealerweise mit vergleichbarer Hardware, Konfiguration und realistischen Datenmengen).
- Während die Testumgebung primär die grundsätzliche Funktionsfähigkeit prüft, geht es im Staging darum, das Verhalten unter realistischen Bedingungen zu verifizieren (bleibt die Performance unverändert, funktionieren die Schnittstellen zu anderen Systemen weiterhin korrekt, kommt es bei realistischer Last zu unerwarteten Effekten, usw.).
- Manche Unternehmen nutzen für Staging eine kleine Gruppe interner Nutzer, die das Update vorab im produktionsnahen Umfeld nutzen, bevor es für alle ausgerollt wird.

# Rollout in die Produktion

- Erst wenn ein Update sowohl die Test- als auch die Staging-Umgebung erfolgreich durchlaufen hat, wird es in der Produktivumgebung eingespielt.
- Auch hier erfolgt der Rollout häufig nicht auf einmal, sondern gestaffelt: zunächst auf einem Teil der Server oder bei einer Gruppe von Nutzern, und erst nach einer Beobachtungsphase ohne Probleme auf die gesamte Umgebung.

# Rollout in die Produktion

- Dieses gestaffelte Vorgehen wird oft als "Rolling Update" bezeichnet.
- Vorteil: ein unentdecktes Problem betrifft nur einen Teil der Infrastruktur, während der Rest weiterhin auf der alten, bekannt funktionierenden Version läuft.
- Wichtig ist außerdem die Möglichkeit eines Rollbacks (also der Rückkehr zum vorherigen Zustand, falls trotz aller Tests ein Problem in der Produktion auftritt).
- Dafür werden vor dem Patchen typischerweise Snapshots oder Backups erstellt.

# Zeitfaktor: Kritikalität vs. Sorgfalt

- Ein wichtiger zusätzlicher Aspekt im Patchmanagement ist die Priorisierung nach Kritikalität, denn nicht jedes Update ist gleich dringend.
- Ein Sicherheitsupdate, das eine aktiv ausgenutzte, kritische Schwachstelle schließt, muss möglicherweise deutlich schneller durch den Prozess laufen als ein reguläres Funktionsupdate.

# Zeitfaktor: Kritikalität vs. Sorgfalt

- Hier entsteht ein Zielkonflikt zwischen Sorgfalt (gründliches Testen) und Geschwindigkeit (schnelles Schließen einer aktiven Bedrohung).
- In der Praxis wird dieser Konflikt durch unterschiedliche Prozesse für unterschiedliche Kritikalitätsstufen gelöst.
- Kritische Sicherheitspatches durchlaufen einen verkürzten, beschleunigten Prozess mit Fokus auf die wichtigsten Systeme, während reguläre Updates den vollständigen, gründlichen Prozess durchlaufen.

# Prüfungsrelevante Einordnung



In der AP2 wird das Patchmanagement-Konzept häufig anhand eines Szenarios geprüft, in dem ein Unternehmen einen strukturierten Update-Prozess einführen möchte.

Eine typische Aufgabe könnte lauten:
„Ein Unternehmen spielt sicherheitsrelevante Updates bisher ungetestet direkt auf den Produktivservern ein. Beurteilen Sie dieses Vorgehen und schlagen Sie ein verbessertes Konzept vor.“

# Prüfungsrelevante Einordnung



Die erwartete Antwort benennt das Risiko ungetesteter Updates (mögliche Inkompatibilitäten und Ausfälle in der Produktion) und schlägt das mehrstufige Modell vor:

Zunächst Test in einer isolierten Umgebung, anschließend Staging unter produktionsnahen Bedingungen, und erst dann ein gestaffelter Rollout in die Produktion mit der Möglichkeit eines Rollbacks.

Wer zusätzlich die Priorisierung nach Kritikalität erwähnt (kritische Sicherheitslücken können einen beschleunigten Prozess durchlaufen) zeigt ein vertieftes, praxisorientiertes Verständnis.

23.09.2026

# Ende